

VULNERABILITY MANAGEMENT POLICY

Revision: 1.0

Issue Status: A

Prepared by	Designation
Krishnan Somaskandan	Product Manager
Approved by	Designation
Gayathri V	Chief Information Security Officer

This document is the property of and proprietary to Ideas2IT. Contents of this document should not be disclosed to any unauthorized person. This document may not, in whole or in part, be reduced, reproduced, stored in a retrieval system, translated, or transmitted in any form or by any means, electronic or mechanical.

	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/ITPP
		Date	14/12/2024
		Revision No	1.0
		Page	1 of 9

Revision History

#	Version	Release Date	Description of the Change	Created/ Modified by	Approved by
1	1.0	16-Dec-2023	Initial	Krishnan S	Gayathri V

Review History

#	Version	Review Date	Description	Created/ Modified by	Reviewed by
1	1.0	16-Dec-2023	Initial	Krishnan S	Gayathri V
2	1.0	14-Dec-2024	Document Review	Krishnan S	Kalpana J

1. Purpose

	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/ITPP
		Date	14/12/2024
		Revision No	1.0
		Page	2 of 9

The purpose of this Vulnerability Management Policy is to ensure the timely identification, classification, remediation, and mitigation of vulnerabilities within our software products, services, and infrastructure. This policy aims to protect organizational assets, client data, and ensure compliance with relevant laws and standards, including those applicable in India, such as the Information Technology Act, 2000, and industry best practices like ISO/IEC 27001.

2. Scope

This policy applies to all systems, applications, and software developed, maintained, or operated by Ideas2IT, including third-party services and cloud-based infrastructures. It includes but is not limited to:

- Internal systems and applications
- Customer-facing software products and services
- Third-party libraries, frameworks, and dependencies
- Network devices, operating systems, and databases
- Cloud services and vendor platforms

3. Policy Statement

Ideas2IT is committed to:

- Proactively identifying vulnerabilities in our software and infrastructure.
- Prioritizing and classifying vulnerabilities based on risk levels.

	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/ITPP
		Date	06/12/2023
		Revision No	1.0
		Page	3 of 9

- Remediating vulnerabilities in a timely and effective manner.
- Regularly reviewing and updating our vulnerability management processes to reflect evolving threats and technology.
- Ensuring that all stakeholders (internal and external) adhere to these policies and practices.

4. Vulnerability Identification

4.1 Regular Vulnerability Scanning

- We will conduct automated vulnerability scans on all critical systems and applications at regular intervals (e.g., monthly, quarterly).
- Scans should include both internal and external assessments, as well as scans of web applications, network devices, databases, and third-party software.

4.2 Manual Testing and Penetration Testing

- Periodic penetration tests will be conducted to identify complex or hidden vulnerabilities that automated scans may miss.
- This includes testing new releases, major changes to existing software, and infrastructure components.

4.3 Third-Party Software and Dependencies

- We will monitor and track known vulnerabilities in third-party libraries, frameworks, and external dependencies used in our software.
 - All open-source software and external vendors used by our organization should have an established vulnerability management process in place.
-

	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/ITPP
		Date	06/12/2023
		Revision No	1.0
		Page	4 of 9

5. Vulnerability Classification and Risk Assessment

5.1 Severity Rating

- Vulnerabilities will be classified based on their severity and potential impact using industry-standard frameworks like the Common Vulnerability Scoring System (CVSS).
- The classification categories include:
 - **Critical:** Exploitable vulnerabilities that can cause significant damage or compromise data integrity, requiring immediate attention.
 - **High:** Vulnerabilities that can have a severe impact if exploited but may not necessarily compromise the entire system.
 - **Medium:** Vulnerabilities that present moderate risk but should still be addressed in a timely manner.
 - **Low:** Minor vulnerabilities that have limited or negligible impact but should be monitored and addressed as part of routine maintenance.

5.2 Risk Assessment

- Risk assessments will be conducted on vulnerabilities to assess the likelihood of exploitation and the potential impact on the business.
- Based on the assessment, the organization will prioritize remediation efforts.

6. Vulnerability Remediation

6.1 Patching and Updates

- Vulnerabilities must be remediated within a predefined timeframe based on their severity:
 - **Critical:** Remediated within 24 hours
 - **High:** Remediated within 7 days

	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/ITPP
		Date	06/12/2023
		Revision No	1.0
		Page	5 of 9

- **Medium:** Remediated within 30 days
 - **Low:** Remediated within 90 days or as part of routine updates
- All patches and security updates should be tested before being deployed in the production environment.

6.2 Exception Process

- In cases where remediation within the standard timeframes is not feasible, an exception request must be submitted. The request must include justification and a compensating control plan to mitigate the risk until remediation is implemented.

6.3 Remediation Verification

- After applying patches or other remediation actions, the effectiveness of the fixes will be verified through vulnerability scanning and/or manual testing.
- All vulnerabilities must be re-scanned to confirm that the remediation has been successful.

7. Monitoring and Reporting

7.1 Continuous Monitoring

- Continuous monitoring tools will be implemented to detect new vulnerabilities, unauthorized changes, or security incidents in real-time.
- This includes monitoring critical systems, applications, and infrastructure for emerging threats.

7.2 Vulnerability Reporting

- Vulnerabilities identified must be logged in a central vulnerability management system with appropriate documentation, including:

 Let's Innovate	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/ITPP
		Date	06/12/2023
		Revision No	1.0
		Page	6 of 9

- Description of the vulnerability
- Affected system or component
- Risk rating
- Remediation actions taken
- Responsible party and timeline

7.3 Audit and Review

- Regular internal audits will be conducted to assess the effectiveness of vulnerability management processes.
- Management will review vulnerability reports and progress toward remediation during quarterly security reviews.

8. Roles and Responsibilities

8.1 Security Team

- Responsible for conducting vulnerability assessments, implementing remediation strategies, and maintaining the vulnerability management system.
- Coordinating with development teams to address vulnerabilities in software products and services.

8.2 Development and Operations Teams

- Collaborating with the security team to identify and fix vulnerabilities in code, configurations, and infrastructure.
- Ensuring that security patches are applied and tested in a timely manner.

8.3 Incident Response Team

- Assisting in investigating and mitigating vulnerabilities exploited during security incidents.

	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/ITPP
		Date	06/12/2023
		Revision No	1.0
		Page	7 of 9

- Coordinating with the security team to implement containment and remediation actions for critical vulnerabilities.

8.4 Management

- Overseeing and approving the vulnerability management program, ensuring sufficient resources and commitment from all departments.
- Reviewing progress and taking corrective actions when necessary.

9. Compliance and Legal Requirements

- All vulnerability management activities must comply with applicable laws and regulations, including:
 - **Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011** under the **Information Technology Act, 2000**.
 - Industry best practices, including those from the **ISO/IEC 27001**, **OWASP**, and others.
 - Data protection and privacy laws (e.g., **GDPR** if applicable, **Personal Data Protection Bill**, 2019 in India).

10. Training and Awareness

- Regular training will be provided to all employees to ensure they are aware of security best practices and vulnerability management procedures.
 - Developers and engineers will receive specialized training on secure coding practices and how to avoid common vulnerabilities.
-

	IT POLICIES AND PROCEDURES	Document Number	I2I/ISMS/ITPP
		Date	06/12/2023
		Revision No	1.0
		Page	8 of 9

11. Review and Continuous Improvement

- The Vulnerability Management Policy will be reviewed annually or after major security incidents.
- Continuous improvement processes will be implemented based on the results of audits, assessments, and lessons learned.

12. Conclusion

The implementation of this Vulnerability Management Policy is critical to maintaining the security, integrity, and availability of our software products and services. By identifying, classifying, and remediating vulnerabilities in a timely manner, [Your Organization Name] will minimize risks to its systems and the sensitive data of its clients.
